

Lineamientos de Ciberseguridad para el Desarrollo Plataformas Web

A continuación, se presenta el listado de requisitos mínimos obligatorios que el proveedor deberá cumplir durante todo el ciclo de vida del proyecto.

A. Gobernanza, Contrato y Cumplimiento

1. Certificaciones del Proveedor:

- El proveedor deberá demostrar que cuenta con certificaciones **vigentes** y emitidas por entidades acreditadas. Se exigirá como mínimo:
 - **Familia ISO/IEC 27000 (Seguridad de la Información):** Específicamente la certificación **ISO/IEC 27001**, que garantiza que el proveedor opera bajo un Sistema de Gestión de Seguridad de la Información (SGSI) reconocido internacionalmente.
 - **Familia ISO 9000 (Gestión de Calidad):** Específicamente la certificación **ISO 9001**, que asegura que el proveedor tiene procesos de calidad estandarizados y maduros para el diseño, desarrollo y entrega del software.

2. Propiedad Intelectual y Código Fuente:

- El contrato debe estipular que Ferreycorp es el propietario del 100% del código fuente y toda la propiedad intelectual generada.
- Se exigirá la entrega de la totalidad del código fuente, sin ofuscar, con su historial de versiones completo (ej. acceso al repositorio Git).
- El proveedor está obligado a eliminar de forma segura y certificada todas las copias del código y datos del proyecto de sus sistemas tras la aceptación final.

3. Responsabilidad y Tercerización:

- El proveedor es el único responsable ante Ferreycorp por la seguridad y calidad del producto final, incluso si terceriza servicios (como el ethical hacking). La confidencialidad y los estándares de seguridad deben extenderse contractualmente a cualquier subcontratista.

4. Derecho a Auditoría:

- Ferreycorp debe reservarse el derecho a auditar el código fuente, los procesos de desarrollo y la infraestructura del proveedor en cualquier momento del proyecto.

5. Software de Terceros (Open Source y Comercial):

- **Software Bill of Materials (SBOM):** El proveedor debe entregar un SBOM completo en un formato estándar (ej. CycloneDX, SPDX) que detalle todos los componentes de terceros, sus versiones y licencias.
- **Análisis de Vulnerabilidades de Componentes (SCA):** El proveedor debe analizar continuamente los componentes de terceros y garantizar que no se utilicen librerías con vulnerabilidades conocidas (CVEs).

6. Gobernanza sobre Componentes Licenciados y de Pago

- **Principio General:** Como norma, el desarrollo de las plataformas deberá priorizar el uso de componentes de código abierto con licencias permisivas o el desarrollo a medida, con el fin de retener la propiedad intelectual total, minimizar costos recurrentes y reducir la dependencia de proveedores externos.
- **Restricción:** Queda restringido el uso de plugins, temas, librerías o cualquier componente de software que requiera la compra de una licencia de pago o genere una suscripción recurrente.
- **Proceso de Excepción:** El uso de un componente de pago solo podrá ser considerado bajo un proceso de excepción formal que requerirá:
 - Una justificación técnica y de negocio detallada que demuestre que el componente es indispensable y que desarrollarlo a medida tendría un costo o complejidad significativamente mayor.
 - La evaluación y aprobación explícita por parte del área de Seguridad de la Información, quien validará la madurez y el soporte del proveedor del componente.
 - La aprobación formal del líder del proyecto o dueño del presupuesto, quien aceptará la responsabilidad sobre los costos recurrentes y el riesgo de dependencia tecnológica.

B. Ciclo de Vida de Desarrollo Seguro (Secure SDLC)

1. Adopción de Frameworks:

- Exigir la adhesión a un framework de desarrollo seguro como OWASP SAMM o NIST SSDF.
- El cumplimiento del **OWASP Top 10 (para Web)**, el **OWASP API Security Top 10 (para los servicios backend)** y el **OWASP MASVS (Mobile Application Security Verification Standard)** no son opcionales, son los requisitos mínimos.

2. Pruebas de Seguridad Estáticas y Dinámicas (SAST/DAST):

- Se deben integrar herramientas para el análisis de seguridad sobre el código de la aplicación web y las APIs del backend. Los reportes limpios de vulnerabilidades críticas, altas, medias o bajas son un requisito para cada entrega.

3. No "Hardcoding" de Secretos:

- Queda estrictamente prohibido incrustar credenciales, tokens, claves de API o cualquier tipo de secreto en el código fuente de cualquier aplicación (web o backend).

C. Requisitos Técnicos de la Aplicación

1. Autenticación y Gestión de Sesiones:

- **Integración con IAM Corporativo (OAuth 2.0 / OIDC):** La autenticación de usuarios **deberá** realizarse exclusivamente a través del sistema de gestión de identidades (IAM) de Ferreycorp. La integración debe usar los estándares **OpenID Connect (OIDC)** para la autenticación y **OAuth 2.0** para la autorización.
- **Gestión de Tokens Segura:** Los tokens deben tener una vida útil corta y ser manejados exclusivamente sobre canales cifrados (TLS).

2. Autorización y Control de Acceso:

- Se debe implementar un Control de Acceso Basado en Roles (RBAC) granular, donde los permisos se asocien a la identidad y roles provenientes del IAM corporativo.

3. Seguridad de la API (API Security):

- Todas las funcionalidades deben ser expuestas a través de una API RESTful segura.
- **Autenticación y Autorización por Endpoint:** Cada endpoint de la API debe validar el token de acceso (OAuth 2.0) y verificar los permisos del usuario para cada operación.
- **Protección contra Abuso:** Implementar mecanismos de limitación de peticiones (Rate Limiting) para prevenir ataques de denegación de servicio (DoS) y fuerza bruta.

4. Logging y Monitoreo:

- Los logs generados no deben contener información sensible y deben ser suficientes para una investigación forense.

D. Entregables de Seguridad y Aceptación Final

1. Reporte de Ethical Hacking:

- Se debe entregar un reporte de pentesting completo, realizado por una empresa tercera de prestigio. El alcance de la prueba **debe incluir obligatoriamente la aplicación web y las APIs del backend.**

2. Reportes SAST, DAST, MAST y SCA:

- Los informes finales y firmados de las herramientas utilizadas, demostrando el cumplimiento de la política de remediación de vulnerabilidades.

3. Documentación Detallada:

- Guía de Instalación y Despliegue Seguro.
- Guía de Hardening de la infraestructura de servidor.
- Manual de Administración y configuración de roles.